

Module 02 — Footprinting et Reconnaissance (CEH v13)

Cours complet expliqué en français

Document pédagogique basé sur le PDF « **CEHv13 - Module 02 - Footprinting and Reconnaissance** » d'EC-Council (certification **CEH**, examen **312-50**). Ce document reprend et **explique** tout le contenu du module, objectif par objectif.

Table des matières

1. Les concepts du footprinting
 2. Le footprinting via les moteurs de recherche
 3. Le footprinting via les services de recherche sur Internet
 4. Le footprinting via les réseaux sociaux
 5. Le footprinting Whois
 6. Le footprinting DNS
 7. Le footprinting réseau et email
 8. Le footprinting via l'ingénierie sociale
 9. Automatiser le footprinting avec des outils avancés et l'IA
 10. Les contre-mesures du footprinting
 11. Aide-mémoire final pour l'examen
-

1. Les concepts du footprinting

1.1 C'est quoi la reconnaissance / le footprinting ?

La **reconnaissance** (également appelée **footprinting**) désigne la **phase préparatoire** au cours de laquelle un attaquant cherche à recueillir **le maximum d'informations possible** sur une cible d'évaluation **avant de lancer une attaque**.

Le footprinting est la **première étape** de l'évaluation de la posture de sécurité de l'infrastructure IT d'une organisation cible. Grâce au footprinting et à la reconnaissance, on peut récupérer un maximum d'informations sur un système informatique, un réseau, et sur **tout périphérique connecté à ce réseau**.

En d'autres termes, le footprinting fournit un « **blueprint** » (**plan d'architecture**) du **profil de sécurité** d'une organisation, et doit donc être mené de manière **méthodique**.

- Il n'existe **pas de méthodologie unique** : les informations peuvent être tracées de nombreuses façons.
- Les informations recueillies aident à **découvrir les vulnérabilités** existantes du réseau cible et à identifier les **différentes façons de les exploiter**.
- Un footprint détaillé donne un maximum d'informations sur l'organisation cible, permettant à l'attaquant de choisir les **exploits adaptés** et d'identifier **le maillon le plus faible** du périmètre de sécurité.

1.2 Les deux types de footprinting

a) Footprinting passif

Collecte d'informations sur la cible **sans interaction directe**. Utile quand la cible ne doit pas détecter la collecte d'informations. Techniquement **difficile**, car aucun trafic actif n'est envoyé vers l'organisation cible : on ne collecte que des informations **archivées et stockées** (moteurs de recherche, réseaux sociaux, etc.).

Il implique : - La collecte d'**OSINT** (Open-Source Intelligence / renseignement en sources ouvertes) ; - L'utilisation de **bases de données propriétaires et de services payants** ; - Le **partage de renseignements** avec des organisations partenaires ou des groupes industriels.

b) Footprinting actif

Collecte d'informations sur la cible **avec interaction directe**. La cible **peut détecter** le processus de collecte d'informations. Il nécessite **plus de préparation** que le footprinting passif, car il peut laisser des traces qui alerteront l'organisation cible.

Il implique : - L'**interrogation DNS** ; - L'**ingénierie sociale** ; - Le **scan de réseau / de ports** ; - L'**énumération d'utilisateurs et de services**.

1.3 Les informations obtenues par le footprinting

Les principaux objectifs du footprinting sont de collecter les **informations réseau, système et organisationnelles** de la cible.

Informations organisationnelles (issues du site web + Whois)

- Détails des **employés** (noms, adresses de contact, fonctions, expérience professionnelle) ;

- Adresses et **numéros de téléphone** (fixe/mobile) ;
- Détails des **succursales et de la localisation** ;
- **Partenaires** de l'organisation ;
- Liens web vers d'autres sites liés à l'entreprise ;
- **Historique** de l'organisation ;
- **Technologies web** utilisées ;
- Articles de presse, **communiqués de presse** et documents associés ;
- Documents **légaux, brevets et marques** déposés.

Informations réseau (via analyse Whois, traceroute, etc.)

- **Domaines et sous-domaines** ;
- **Blocs réseau** (NetBlocks) ;
- Topologie réseau, **routeurs de confiance et pare-feu** ;
- **Adresses IP** des systèmes joignables ;
- Enregistrements **Whois** ;
- Enregistrements **DNS** et informations associées.

Informations système (via footprinting réseau, DNS, site web, email)

- **OS des serveurs web** ;
- **Localisation** des serveurs web ;
- **Adresses email publiquement disponibles** ;
- Noms d'utilisateurs et mots de passe (lorsqu'ils fuient) ;
- Technologies web.

À retenir : l'attaquant peut ensuite utiliser ces informations pour **créer une carte du réseau**, mener des attaques d'**ingénierie sociale**, obtenir des **détails internes** du réseau, et bâtir une **stratégie de hacking** en identifiant l'emplacement des **pare-feu, proxys et autres solutions de sécurité**.

1.4 Les menaces rendues possibles par le footprinting

Menace	Description
Ingénierie sociale	Sans aucune intrusion technique, les hackers collectent des informations par la persuasion et d'autres moyens, auprès d'employés volontaires ignorant leurs intentions
Attaques système et réseau	Le footprinting révèle la configuration système, l'OS, etc. L'attaquant trouve puis exploite les vulnérabilités, pouvant prendre le contrôle d'un système ou du réseau entier
Fuite d'informations	Des informations sensibles tombent entre les mains d'attaquants qui montent une attaque ou les revendent à but lucratif
Perte de vie privée	Accès aux systèmes/réseaux et escalade de privilèges jusqu'au niveau admin → perte de confidentialité pour l'organisation et ses employés
Espionnage concurrentiel	Des concurrents récupèrent des données sensibles pour lancer des produits similaires, modifier les prix et affaiblir la position de la cible

1.5 La méthodologie du footprinting

Il n'y a pas de méthode unique. Le module présente une **méthodologie type** qui organise les techniques passives et actives :

- **Footprinting passif** : moteurs de recherche (techniques avancées de Google hacking, Google Hacking Database, services de recherche de personnes, moteur Shodan), services financiers et sites d'emploi, `archive.org`, sites de médias sociaux, analyse de graphes sociaux, renseignement concurrentiel et sites de profils d'entreprise, groupes/forums/blogs, outils de recherche sur le dark web.
 - **Footprinting passif/Whois** : Whois lookup, IP geolocation lookup.
 - **Footprinting actif** : interrogation DNS, reverse DNS lookup, traceroute, tracking des communications email.
 - **Footprinting via l'ingénierie sociale** : eavesdropping, shoulder surfing, dumpster diving, impersonation.
 - **Automatisation** : outils (Maltego, Recon-ng, FOCA, OSINT Framework...), création de scripts Python personnalisés avec l'IA.
-

2. Le footprinting via les moteurs de recherche

2.1 Rôle des moteurs de recherche

Les moteurs de recherche jouent un **rôle majeur** dans l'extraction de détails critiques sur une cible. Ils utilisent des logiciels automatisés (les **crawlers** / robots d'exploration) qui **scannent en continu** les sites web actifs et ajoutent les résultats dans **l'index** du moteur, stocké dans une base de données massive. Quand l'utilisateur interroge l'index, le moteur renvoie une liste de **SERP** (Search Engine Results Pages) : pages web, vidéos, images et différents types de fichiers, classés et affichés selon leur pertinence.

Ces résultats peuvent révéler : plateformes technologiques, détails des employés, pages de connexion, portails intranet, informations de contact... utiles pour l'ingénierie sociale et d'autres attaques.

Principaux moteurs : **Google, Bing, Yahoo, Ask, AOL, Baidu, Yandex, WolframAlpha, DuckDuckGo.**

2.2 Le Google hacking (techniques avancées)

Le **Google hacking** consiste à utiliser les **opérateurs de recherche avancés de Google** pour créer des requêtes complexes et extraire des informations **sensibles ou cachées**, aidant à trouver des cibles vulnérables.

Syntaxe : `opérateur: terme_de_recherche` — sans espace entre l'opérateur et le terme.

Les opérateurs Google à connaître

Opérateur	Rôle	Exemple
<code>site:</code>	Restreint aux résultats d'un site/ domaine donné	<code>games site:www.certifiedhacker.com</code>
<code>allinurl:</code>	Pages contenant tous les termes dans l'URL	<code>allinurl: google career</code>
<code>inurl:</code>	Pages contenant le terme dans l'URL	<code>inurl:copy site:www.google.com</code>
<code>intext:</code>	Pages contenant le mot-clé dans le corps de la page	<code>intext:"vpn configuration"</code>
<code>allintitle:</code>	Pages contenant tous les termes dans le titre	<code>allintitle: detect malware</code>
<code>intitle:</code>	Pages contenant le terme dans le titre	<code>malware detection intitle:help</code>
<code>inanchor:</code>	Pages dont le texte d'ancrage des liens contient le terme	<code>Anti-virus inanchor:Norton</code>
<code>allinanchor:</code>	Pages dont les ancres contiennent tous les termes	<code>allinanchor: best cloud service provider</code>
<code>cache:</code>	Affiche la version en cache de la page	<code>cache:www.eff.org</code>
<code>link:</code>	Sites qui contiennent des liens vers la page indiquée	<code>link:www.googleguide.com</code>
<code>related:</code>	Sites similaires ou liés à l'URL indiquée	<code>related:www.microsoft.com</code>
<code>info:</code>	Présente des informations sur une page	<code>info:gothotel.com</code>

Opérateur	Rôle	Exemple
location:	Recherche pour une localisation précise	location: 4 seasons restaurant
filetype:	Recherche par extension de fichier	jasmine.jpg (fichiers jpg)
source:	Affiche les infos d'un site précis dans Google News	Malware news source:"Hacker News"
phonebook:	Trouve les numéros de téléphone résidentiels/pro	phonebook:Sundar Pichai
before:	Filtre les contenus publiés avant une date	ransomware before:2020-06-29
after:	Filtre les contenus publiés après une date	site:wikipedia.org after:2023-01-01 artificial intelligence

Selon la documentation Google, **link: ne peut pas être combinée** avec une recherche par mot-clé normal ; combinée à un autre opérateur avancé, Google peut ne pas renvoyer toutes les pages correspondantes.

Que peut faire un hacker avec le Google hacking ?

- Détecter les **sites web et serveurs web vulnérables** à l'exploitation (buffer overflow, SQL injection...) ;
- Localiser des **informations privées et sensibles** sur la cible ;
- Extraire via la **GHDB** : messages d'erreur contenant des infos sensibles, **fichiers contenant des mots de passe, répertoires sensibles**, pages de **portails de connexion**, données réseau/vulnérabilités (logs IDS/pare-feu), **advisories et vulnérabilités de serveurs**, versions de logiciels, **code source** d'applications web, **appareils IoT connectés** non protégés, pages cachées (intranet, services VPN).

Exemple classique : `[intitle:intranet inurl:intranet intext:"human resources"]` → recherche des intranets accessibles contenant le terme « human resources ».

Google hacking avec l'IA (ShellGPT / ChatGPT)

Un attaquant peut utiliser **ShellGPT** (commande `sgpt --chat footprint --shell "..."`) pour automatiser les recherches. Exemple de prompt : « *Use filetype search operator to obtain pdf files on the target website eccouncil.org and store the result in the recon1.txt file* » → l'IA génère la commande :

```
lynx --dump "http://www.google.com/search?q=site:eccouncil.org+filetype:pdf" | grep "http" | cut -d"=" -f2 | grep -o "http[^&]*" > recon1.txt
```

- `lynx --dump` : ouvre Google en mode texte pour obtenir les résultats ;
- `grep "http"` : filtre les lignes contenant « http » ;
- `cut -d"=" -f2` : découpe chaque ligne au délimiteur = et garde le 2^e champ ;
- `grep -o "http[^&]*"` : extrait les URL en excluant les paramètres ;
- `> recon1.txt` : enregistre le résultat.

2.3 La Google Hacking Database (GHDB)

La **GHDB** (`exploit-db.com/google-hacking-database`) est un sous-ensemble d'**Exploit-DB** qui recense des requêtes Google (« **Google Dorks** ») permettant de trouver des informations sensibles exposées par erreur.

Catégories GHDB : Footholds, Files Containing Juicy Info, Files Containing Usernames, Files Containing Passwords, Sensitive Directories, Sensitive Online Shopping Info, Web Server Detection, Network or Vulnerability Data, Vulnerable Files, Pages Containing Login Portals, Vulnerable Servers, Various Online Devices, Error Messages, Advisories and Vulnerabilities.

Usages par un attaquant : reconnaissance, exploitation de mauvaises configurations, recherche de systèmes vulnérables, récolte d'identifiants (credential stuffing / brute force), identification de ports et services ouverts.

SearchSploit : outil en ligne de commande qui copie localement la base d'Exploit-DB pour des recherches hors-ligne, utile sur des réseaux segmentés ou **air-gapped** (sans accès Internet).

VPN Footprinting via GHDB (dorks VPN)

Google Dork	Description
<code>inurl:"/sslvpn_logon.shtml" intitle:"User Authentication"</code>	Pages contenant des portails de connexion
<code>inurl:/sslvpn/Login/Login</code>	Portails de connexion VPN
<code>site:vpn.*/*/ intitle:"login" inurl:weblogin</code>	Pages de connexion VPN variées
<code>intitle:"index of" /etc/openvpn/</code>	Répertoires sensibles
<code>"-----BEGIN OpenVPN Static key V1-----" ext:key</code>	Clés statiques OpenVPN
<code>intitle:"index of" "vpn-config.*"</code>	Fichiers de config VPN
<code>Index of / *.ovpn</code>	Fichiers de configuration OpenVPN, certificats, clés
<code>inurl:"/vpn/tmindex.html" vpn</code>	Portails Netscaler / Citrix Gateway
<code>intitle:"SSL VPN Service" + intext:"..."</code>	Pages de connexion Cisco ASA
<code>intext:"FortiClient" inurl:remote/login</code>	Pages de connexion Fortinet VPN

Avec l'IA : prompt « *Use inurl search operator to obtain the Fortinet VPN login pages* » → l'IA génère une commande `lynx --dump` similaire interrogeant Google avec `inurl:"remote login" fortinet OR fortigate OR "ssl vpn"`.

2.4 Le footprinting via Shodan

Shodan (shodan.io) est un moteur de recherche qui permet de faire du footprinting à différents niveaux : il **détecte les appareils et réseaux vulnérables**. Une recherche Shodan sur « VoIP » et « VPN » renvoie des résultats utiles pour le footprinting VPN/VoIP : initiateur/responder SPI, protocoles (SIP, IKE), version, drapeaux (encryption, authentication), ports (5060, 500, 4500, 443, 1723...).

2.5 Autres techniques de footprinting via les moteurs de recherche

Recherche avancée Google et recherche inversée d'images

- **Google Advanced Search** (google.com/advanced_search) : recherche web complexe sans taper les opérateurs (champs : tous ces mots, expression exacte, langue, région, site/domaine, type de fichier, droits d'usage...). Permet de trouver les sites qui pointent vers le site de la cible (**partenaires, fournisseurs, clients, affiliations**).
- **Google Advanced Image Search** (google.com/advanced_image_search) : recherche d'images par couleur, domaine, type de fichier, taille, mot-clé...
- **Reverse Image Search** (google.com/imghp) : utilise une **image comme requête** (upload ou URL). Le moteur affiche toutes les localisations en ligne de l'image → traçage de la source et des détails

(photos, photos de profil, mèmes). Outils : Google Image Search, **TinEye**, Yahoo Image Search, Bing Image Search, Pinterest.

Moteurs de recherche vidéo

YouTube, Google videos, Yahoo videos, Bing videos permettent de rechercher des vidéos par **format et durée**. L'analyse des vidéos (heure/date, miniatures) se fait avec des outils d'analyse vidéo : **YouTube Metadata**, **YouTube DataViewer**, **MW Metadata**, **EzGif**, **VideoReverser.com**.

Moteurs de recherche méta

Les **méta moteurs** (Startpage, MetaGer, eTools.ch) n'ont pas leur propre index : ils envoient la requête à plusieurs moteurs tiers (Google, Bing, Ask.com...), filtrent les doublons, et **masquent l'adresse IP de l'utilisateur**. Ils permettent de récupérer plus de résultats avec le même effort (sites de shopping, images, vidéos, blogs, news).

Moteurs de recherche FTP

De nombreuses organisations stockent des archives sur des serveurs FTP, souvent **laissés non sécurisés**. Des moteurs FTP (**NAPALM FTP Indexer**, **FreewareWeb FTP File Search**, **Mamont**, **Globalfilesearch.com**) permettent de chercher des fichiers critiques : stratégies commerciales, documents fiscaux, dossiers personnels des employés, données financières, logiciels sous licence. Client FTP courant : **FileZilla**.

Dorks FTP utiles : `intitle:"Index of" ws_ftp.ini` (contient les noms d'utilisateur/mots de passe FTP), `intitle:"Index of ftp passwords"`, `allintitle:"CrushFTP WebInterface"`, etc.

Moteurs de recherche IoT

Les moteurs IoT (**Shodan**, **Censys**, **ZoomEye**) explorent Internet à la recherche d'**appareils IoT accessibles publiquement** : systèmes SCADA, systèmes de contrôle du trafic, appareils électroménagers connectés, appareils industriels, caméras CCTV. Beaucoup sont **sans mot de passe ou avec des identifiants par défaut**. Ils fournissent : fabricant, localisation géographique, adresse IP, hostname, ports ouverts. L'attaquant peut ainsi établir une **backdoor** vers l'appareil et lancer d'autres attaques.

3. Le footprinting via les services de recherche sur Internet

Les services de recherche sur Internet (recherche de personnes, alertes, services financiers, sites d'emploi) fournissent des informations sur la cible : détails de l'infrastructure, localisation physique, détails des employés.

3.1 Trouver les TLD et sous-domaines d'une entreprise

Les **TLD** (Top-Level Domains) et **sous-domaines** donnent beaucoup d'informations. Un sous-domaine n'est accessible qu'à quelques personnes (employés, membres d'un département). Les administrateurs créent souvent des sous-domaines pour **tester de nouvelles technologies** avant déploiement : souvent **en phase de test, donc moins sécurisés et plus vulnérables**. Ils révèlent les différents départements et unités métier.

Méthodes : - Rechercher l'URL externe de l'entreprise dans un moteur de recherche ; - **Essais-erreurs** sur des formats courants de sous-domaines ; - Utiliser **Netcraft** (netcraft.com) : liste tous les sous-domaines liés au domaine cible ; - Utiliser l'opérateur Google : `site:microsoft.com -inurl:www` ; - **DNSdumpster** (dnsdumpster.com) : outil de recherche de domaine découvrant les hôtes liés à un domaine ; - **Pentest-Tools Find Subdomains** : découvre sous-domaines, IP, OS, serveurs, technologies, plateformes web, titres de pages.

TLD et sous-domaines avec l'IA

Prompts typiques : 1. « *Discover all the subdomains of 'google.com' using dig command* » → génère une commande `dig +short google.com NS | xargs -I{} dig +nocmd +noall +answer @{} google.com A | grep -E 'CNAME|A|AAAA'`. 2. « *Use Sublist3r to gather a list of subdomains of the target organization eccouncil* » → génère `sublist3r -d eccouncil.org -o eccouncil_subdomains.txt`. Sublist3r interroge Baidu, Yahoo, Google, Bing, Ask, Netcraft, DNSdumpster, VirusTotal, ThreatCrowd.

3.2 Extraire des informations de site web via archive.org

archive.org (Internet Archive Wayback Machine) explore les **versions archivées des sites web** depuis leur création. Un attaquant peut récupérer des informations **supprimées** du site cible (pages web, audio, vidéo, images, texte, logiciels) pour mener du **phishing** et d'autres attaques.

Photon (python3 photon.py -u http://www.certifiedhacker.com -l 3 -t 200 --wayback) permet de récupérer les URL archivées de la cible depuis archive.org. Variante `--only-urls` pour n'afficher que les URL.

3.3 Le footprinting via les services de recherche de personnes et les sites d'emploi

Services de recherche de personnes

Spokeo, Intelius, pipl, BeenVerified, Whitepages, Instant Checkmate, PeekYou fournissent : noms, adresses, coordonnées, date de naissance, photos, vidéos, profession, famille et amis, profils sociaux, informations immobilières, casier judiciaire. L'attaquant peut ensuite tenter d'obtenir des détails bancaires, cartes de crédit, historique... utiles pour lancer des attaques.

Sites d'emploi

Dice, LinkedIn, Glassdoor, Simply Hired révèlent la **technologie interne** : pare-feu, type de serveur interne, OS utilisés, appliances réseau, hyperviseurs, VMs, schéma de base de données. Une offre « Network Administrator » détaille par exemple les pare-feu (3 FW), 40 hyperviseurs, 1 600 VMs, IPAM Windows/Linux, etc. Les **CV des employés** publiés révèlent aussi des informations techniques.

3.4 Le footprinting sur le dark web

Surface web, deep web, dark web

- **Surface web** : couche externe, indexée, accessible via Chrome/Firefox/Opera ;
- **Deep web** : contenu **caché et non indexé**, quasi-toute la largeur du web (bases de données gouvernementales, etc.) ; accessible via Tor Browser et WWW Virtual Library ;
- **Dark web / Darknet** : couche **plus profonde**, sous-ensemble du deep web, accessible uniquement via des outils spécialisés (navigateurs darknet).

Outils du dark web

- **Tor Browser** (torproject.org) : agit comme un **VPN par défaut** et fait **rebondir l'adresse IP** à travers plusieurs serveurs avant d'interagir avec le web. Il donne accès à des contenus cachés, sites non indexés, bases chiffrées.
- **ExoneraTor, OnionLand Search engine**.

Ces outils permettent de trouver des données confidentielles : détails de cartes de crédit, passeports, cartes d'identité, dossiers médicaux, comptes de médias sociaux, **numéros de sécurité sociale (SSN)**.

Recherche avancée sur le dark web

Paramètres utiles : profils personnels ("John Doe" `site:facebook.com` OR `site:linkedin.com`), publications scientifiques (`site:scholar.google.com`), dossiers judiciaires ("John Doe" `court records`), dossiers médicaux ("John Doe" `medical records`), historique de localisation ("John Doe" `location history`).

Requêtes type pour le footprinting dark web (tableau)

Requête	Type d'information
<code>filetype:pdf site:onion confidential</code>	PDF sensibles sur sites .onion
<code>inurl:config filetype:txt password</code>	Mots de passe dans fichiers de config
<code>filetype:xlsx site:onion financial</code>	Documents financiers Excel
<code>filetype:sql site:onion dump</code>	Dumps de bases de données
<code>filetype:csv site:onion email</code>	Listes d'emails
<code>intitle:"login credentials" filetype:docx</code>	Identifiants de connexion
<code>filetype:xml inurl:config server</code>	Configurations serveur
<code>filetype:key site:onion private</code>	Clés privées
<code>filetype:pdf site:onion "medical records"</code>	Dossiers médicaux
<code>filetype:ppt site:onion "business plan"</code>	Plans d'affaires
<code>filetype:py site:onion "def "</code>	Code source Python
<code>filetype:docx site:onion "legal document"</code>	Documents légaux
<code>filetype:pdf site:onion "bank statement"</code>	Relevés bancaires

Requête	Type d'information
filetype:pdf inurl:patent confidential	Propriété intellectuelle
filetype:txt inurl:exploit "security vulnerability"	Vulnérabilités de sécurité

3.5 Déterminer le système d'exploitation (OS fingerprinting)

La technique consistant à obtenir des informations sur l'OS du réseau cible s'appelle l'**OS fingerprinting**. Outils en ligne : **Netcraft**, **Shodan**, **Censys**. Ils donnent : ville, pays, latitude/longitude, hostname, OS, adresse IP → aide à identifier vulnérabilités et exploits.

- **Netcraft** (netcraft.com/tools , champ « What's that site running? ») : identifie tous les sites associés au domaine cible **ainsi que l'OS de chaque site** (Windows Server 2008/2016, Linux...).
- **Shodan** : cherche les appareils connectés à Internet (routeurs, serveurs, IoT), par ville/pays/coordonnées/hostname/OS/IP ; recherche des vulnérabilités et exploits connus (Exploit DB, Metasploit, CVE, OSVDB, Packetstorm) depuis une interface unique.
- **Censys** (censys.io) : surveille l'infrastructure, découvre les actifs inconnus, vue complète de chaque serveur/appareil exposé (OS, IP, protocoles, localisation).

3.6 La collecte de renseignement concurrentiel

Le **renseignement concurrentiel (competitive intelligence)** est le processus d'identification, collecte, analyse, vérification et utilisation d'informations sur **vos concurrents**, à partir de ressources comme Internet. Il est **non intrusif et subtil**, contrairement au vol de propriété intellectuelle via le hacking ou l'espionnage industriel. Il est réalisé de manière **éthique et légale**.

Il aide à déterminer : ce que font les concurrents, comment ils positionnent produits/services, ce que disent les clients de leurs forces/faiblesses.

- **Approche directe** : salons professionnels, ingénierie sociale auprès d'employés et clients.
- **Approche indirecte** : sites d'entreprises et annonces d'emploi, threads de support et avis, moteurs de recherche et bases en ligne, publications sur les réseaux sociaux, communiqués et rapports annuels, journaux de l'industrie, brevets et marques, catalogues produits, interviews clients/fournisseurs, agents/distributeurs, blogs spécialisés, bases juridiques (**LexisNexis**), bases d'affaires (**D&B Hoovers**), offres d'emploi en ligne, dépôts financiers, solutions technologiques (**Crunchbase**), analyse de propriété intellectuelle.

Questions auxquelles répond le renseignement concurrentiel : **Quand l'entreprise a-t-elle commencé ? Comment s'est-elle développée ? Qui la dirige ? Où est-elle située ? Quels sont ses plans ? Que disent les experts ?**

Sites de ressources d'information

- **EDGAR** (sec.gov/edgar) : dépôts automatisés auprès de la **SEC** américaine ;
- **D&B Hoovers** : base commerciale de 120 millions d'enregistrements ;
- **LexisNexis** : base électronique de documents légaux et publics ;
- **Business Wire** : distribution de communiqués de presse ;
- **Factiva** : base mondiale de 33 000+ sources, 28 langues.

Sites pour connaître les plans de l'entreprise

- **MarketWatch** : marchés, actualités financières ;
- **The Wall Street Transcript** : rapports d'industrie, interviews de dirigeants ;
- **Euromonitor** : recherche sur les marchés de consommation ;
- **Experian** : stratégies marketing des concurrents ;

- **The Search Monitor** : suivi des marques et des publicités ;
- **USPTO** : informations brevets et marques.

Sites pour obtenir l'avis des experts

- **SEMRush** : mots-clés et AdWords d'un site, concurrents SEO/SEA ;
- **ABI/INFORM Global** : base de données d'affaires ;
- **SimilarWeb** : trafic, géographie, référents des sites web et apps ;
- **SERanking** : dynamique de trafic du site cible, recherche PPC concurrente.

3.7 Autres techniques de footprinting via les services Internet

Technique	Informations collectées	Outils
Localisation géographique de la cible	Entrées de bâtiments, caméras, portails, cachettes, faiblesses des clôtures	Google Earth, Google Maps, Wikimapia
Services financiers	Valeur boursière, profil, concurrents, taux de change	Google Finance, MSN Money, Yahoo Finance
Sites de profils d'entreprise	Localisation, adresses, contacts, base d'employés, secteur	opencorporates, Crunchbase, corporationwiki
Alertes de surveillance	Mentions du nom, membres, site ou projets	Google Alerts, X Alerts, Giga Alerts
Suivi de la réputation en ligne	Ranking, notifications email, conversations, social news	Mention, ReviewPush, Reputology
Groupes, forums et blogs	Informations réseau publiques, système, personnel	Google Groups, LinkedIn Groups
Dépôts de code source publics	Fichiers de config, clés SSH/SSL privées, code source, libs, outils	Recon-ng

Réputation en ligne (ORM)

L'**Online Reputation Management (ORM)** est le processus de suivi de ce qui s'affiche quand quelqu'un recherche la réputation de votre entreprise. Les organisations deviennent plus **transparentes**, ce qui peut **aider l'attaquant** à collecter des informations authentiques. Outils : Mention (live, rapports temps réel par email), ReviewPush, Reputology.

Groupes, forums, blogs

Les employés révèlent souvent des infos dans les forums/blogs/groupes : nom complet, lieu de travail et de résidence, téléphones, emails personnels et professionnels, photos du lieu de travail, photos de récompenses. L'attaquant peut s'inscrire avec de faux profils dans Google Groups/LinkedIn Groups et chercher par **FQDN, adresse IP et nom d'utilisateur**.

Dépôts de code source publics

GitHub, GitLab, SourceForge, BitBucket contiennent des données sensibles : fichiers de config, clés SSH/SSL privées, code source, bibliothèques dynamiques. Les informations collectées, combinées à du footprinting actif, permettent du **spear phishing** ciblé, de l'ingénierie sociale et des attaques d'infrastructure. **Recon-ng** permet de découvrir ces dépôts (`workspaces create Github Repositories`, `marketplace search`, module `recon/repositories-vulnerabilities/github_dorks`).

4. Le footprinting via les réseaux sociaux

4.1 Différence avec l'ingénierie sociale

Dans le footprinting via l'**ingénierie sociale**, l'attaquant **trompe les personnes** pour leur faire révéler des informations ; dans le footprinting via les **réseaux sociaux**, l'attaquant **collecte les informations déjà disponibles** sur ces sites. Les réseaux sociaux peuvent aussi être utilisés comme un **média pour mener des attaques d'ingénierie sociale**.

4.2 La recherche de personnes sur les réseaux sociaux

La recherche de personnes est facile : de nombreux sites permettent de chercher **sans s'inscrire**, ce qui rend la démarche **simple et anonyme**.

- On peut rechercher par **nom, email ou adresse** ; certains sites permettent même de vérifier si un compte est **actif** (statut de la personne recherchée).
- **Facebook, Twitter, LinkedIn, Instagram** permettent de trouver des personnes par **nom, mot-clé, entreprise, école, amis, collègues** et personnes vivant à proximité.
- Résultats obtenus :
 - **Personnelles** : nom, poste, nom de l'organisation, localisation actuelle, qualifications éducatives ;
 - **Professionnelles** : entreprise/activité, localisation, numéro de téléphone, email, photos, vidéos.
 - **Twitter** est utilisé pour partager conseils, actualités, opinions, rumeurs et faits.

4.3 Collecter des informations depuis LinkedIn

LinkedIn est le réseau social des professionnels. Il contient : nom, poste, nom de l'organisation, localisation actuelle, qualifications éducatives. Ces informations aident l'attaquant à mener du **social engineering** ou d'autres attaques.

theHarvester

Outil conçu pour les premières phases d'un test de pénétration : il sert à la **collecte d'OSINT** et aide à déterminer le **paysage de menaces externes** d'une entreprise. Les attaquants l'utilisent pour **énumérer les employés** de la société cible ainsi que leurs **postes** sur LinkedIn.

```
theHarvester -d microsoft -l 200 -b linkedin
```

- **-d** : domaine ou nom de société à rechercher ;
- **-l** : nombre de résultats à récupérer ;
- **-b** : source de données (ici `linkedin`).

Résultat type : liste des employés (Software Engineer, Vice President, Operations Manager, Account Executive, Security Consultant...) avec leurs intitulés de poste → utile pour le **social engineering**.

4.4 La récolte de listes d'emails (email harvesting)

Collecter les adresses email publiques des employés est un **vecteur d'attaque important** pour les phases suivantes du hacking. Des outils automatisés comme **theHarvester** et **Email Spider** récoltent les adresses liées à un domaine via **Google, Bing, Yahoo, Baidu...** Ces listes et noms d'utilisateur servent au **social engineering** et aux attaques de **brute force**.

```
theharvester -d microsoft.com -l 200 -b baidu
```

Récolte d'emails avec l'IA

Prompt : « Use theHarvester to gather email accounts associated with 'microsoft.com', limiting results to 200, and leveraging 'baidu' as a data source » → l'IA génère :

```
theHarvester -d microsoft.com -l 200 -b Baidu -f "Microsoft emails.xml"
```

- `-d` : domaine cible ; `-l` : limite de résultats ; `-b` : source de données ; `-f` : fichier de sortie (ici au format XML).

4.5 Analyser la présence sociale de la cible

Plusieurs services en ligne permettent de récupérer des informations sur une cible depuis un ou plusieurs réseaux sociaux : contenu le plus partagé via **hashtags ou mots-clés**, suivi de comptes et d'URL, adresses email... Ces infos servent au **phishing**, au **social engineering** et à d'autres attaques.

- **BuzzSumo** (buzzsumo.com) : moteur de recherche sociale avancé qui trouve le **contenu le plus partagé** pour un sujet, un auteur ou un domaine (Twitter, Facebook, LinkedIn, Google Plus, Pinterest). Donne les comptes sociaux, les URL et les adresses email associées.
- **Google Trends**, **Hashatit**, **Ubersuggest** : autres outils de veille sociale.

4.6 Outils pour le footprinting via les réseaux sociaux

Ces outils collectent des informations sensibles : **date de naissance, qualifications éducatives, statut d'emploi, noms de proches**, et sur l'organisation : **stratégie commerciale, clients potentiels, projets à venir**.

Outil	Rôle
Sherlock (github.com)	Recherche un nom d'utilisateur cible sur un très grand nombre de réseaux sociaux et renvoie l' URL complète de chaque profil trouvé
Social Searcher (social-searcher.com)	Recherche en temps réel de contenu sur les réseaux sociaux avec analytiques avancées (mentions, utilisateurs, sentiment)

```
sherlock "Elon Musk" # ex. avec Sherlock
```

Exemple Social Searcher : recherche « Bill Gates » → 490 mentions, 321 utilisateurs, sentiment 7:3, URL des profils (Wikipedia, gatesnotes, Forbes, Bloomberg...), publications et dates.

4.7 Footprinting via les réseaux sociaux avec l'IA

Prompt : « Use Sherlock to gather personal information about Sundar Pichai and save the result in recon2.txt » → l'IA génère :

```
sherlock SundarPichai --output recon2
```

- `sherlock` : exécute Sherlock ; `SundarPichai` : nom recherché ; `--output recon2` : fichier de sortie.

Résultat (recon2.txt) : liste des profils en ligne trouvés (about.me, Academia.edu, Amino, Behance, Blogger, CGTrader, CNET, Codecademy, Codeforces, CodersRank, Disqus, Duolingo, Fiverr, Freelancer, Giphy...).

5. Le footprinting Whois

5.1 Qu'est-ce que Whois ?

Whois est un **protocole de requête/réponse** utilisé pour interroger les bases de données qui stockent les **utilisateurs enregistrés** (assignataires) d'une ressource Internet : nom de domaine, bloc d'adresses IP, système autonome (AS).

- Le protocole **écoute sur le port 43 (TCP)**.
- Les bases de données Whois sont maintenues par les **Regional Internet Registries (RIR)** et contiennent les **informations personnelles des propriétaires de domaines**.
- Pour chaque ressource, la base fournit un enregistrement texte avec des informations sur la ressource et sur ses assignataires, registrants, et données administratives (dates de création et d'expiration).

À retenir : le **port 43 (TCP)** est le port du protocole Whois.

5.2 Les trois modèles de données Whois

Modèle	Description
Thick Whois (modèle distribué)	Stocke toutes les informations Whois de tous les registrars pour un ensemble de données particulier
Thin Whois (modèle centralisé)	Ne stocke que le nom du serveur Whois du registrar d'un domaine, qui détient lui les détails complets des données recherchées
Whois décentralisé	Stocke les informations complètes, avec plusieurs entités indépendantes gérant la base

5.3 Informations renvoyées par une requête Whois

- Détails du **nom de domaine** et du **registrar** ;
- **Coordonnées du propriétaire** du domaine ;
- **Serveurs de noms** (name servers) ;
- **NetRange** ;
- **Date de création** du domaine ;
- **Enregistrements d'expiration** ;
- **Dernière mise à jour** de l'enregistrement ;
- **Statut du domaine** (disponible, enregistré, suspendu) ;
- Informations sur l'**adresse IP**.

L'attaquant peut ainsi **créer une carte du réseau** de l'organisation, **tromper les propriétaires de domaines** par social engineering et **obtenir les détails internes** du réseau.

5.4 Les Regional Internet Registries (RIR)

Les RIR gèrent l'attribution des adresses IP et des ASN par région :

RIR	Région	Site web
ARIN	Amérique du Nord	arin.net
AFRINIC	Afrique	afrinic.net
APNIC	Asie-Pacifique	apnic.net
RIPE NCC	Europe (Réseaux IP Européens)	ripe.net
LACNIC	Amérique latine et Caraïbes	lacnic.net

5.5 Les outils Whois

- **whois.domaintools.com** et **tamos.com** : effectuent un Whois lookup sur un domaine ou une adresse IP. Résultat type : Registrant, Registrar (IANA ID, URL, Whois server), statut du registrar, dates (création, expiration, mise à jour), name servers, contacts technique/admin, adresse IP, localisation IP (ville/état), ASN, historiques IP/Registrar/Hosting, statut du domaine.
- **Batch IP Converter** (sabsoft.com) : fournit des informations sur une adresse IP, un hostname ou un domaine (pays, état/province, ville, téléphone, fax, fournisseur réseau, contact admin, contact support technique). Supporte les **IDN** (noms de domaine en caractères non anglais) et les **adresses IPv6**.
- **Whois Domain Lookup, Active Whois** : autres outils de Whois lookup sur le domaine cible.

5.6 Trouver les informations de géolocalisation IP

La **géolocalisation IP** permet d'obtenir : pays, région/état, ville, latitude/longitude de la ville, code postal, fuseau horaire, **vitesse de connexion**, **ISP** (société d'hébergement), nom de domaine, code pays IDD, code de zone, station météo, **opérateur mobile**, altitude.

- Outils : **IP2Location** (ip2location.com), **IP Location Finder**, **IP Address Geographical Location Finder**.
- Exemple IP2Location : IP 207.46.232.182 → pays Singapour [SG], ville Singapour, coordonnées, fuseau UTC+08:00, domaine microsoft.com, ASN AS8075 (Microsoft Corporation), type « Data Center ».

Pourquoi c'est dangereux : l'attaquant peut monter un serveur web compromis près de la localisation de la victime, infecter l'appareil avec un malware adapté à la région, ou lancer des attaques de social engineering (spamming, phishing), de la surveillance et des attaques non techniques (dumpster diving, hoaxing, faux expert technique).

6. Le footprinting DNS

6.1 Extraction d'informations DNS

Après les enregistrements Whois, la phase suivante de la méthodologie est le **footprinting DNS**. Il permet de collecter des informations sur les **serveurs DNS**, les **enregistrements DNS** et les **types de serveurs** utilisés par l'organisation cible.

- Les données de zone DNS incluent : **noms de domaines DNS**, **noms d'ordinateurs**, **adresses IP** et bien d'autres informations sur le réseau.
- L'attaquant utilise ces informations pour déterminer les **hôtes clés du réseau**, puis mène des attaques de **social engineering** pour en obtenir encore plus.

6.2 Les enregistrements DNS

Type	Description
A	Pointe vers l'adresse IP d'un hôte (IPv4)
AAAA	Pointe vers l'adresse IPv6 d'un hôte
MX	Pointe vers le serveur de mail d'un domaine
NS	Pointe vers le serveur de noms d'un hôte
CNAME	Nommage canonique : permet des alias vers un hôte
SOA	Indique l' autorité pour un domaine
SRV	Enregistrements de services
PTR	Associe une adresse IP à un hostname (reverse DNS)
RP	Personne responsable (responsible person)
HINFO	Enregistrement d'informations d'hôte : type de CPU et OS
TXT	Enregistrements texte non structuré

6.3 Les outils d'interrogation DNS

Les outils d'interrogation DNS (**SecurityTrails**, **Fierce**, **DNSChecker**, **zdns**, **DNSdumpster**) peuvent extraire une plage d'adresses IP via un **IP routing lookup**. Si le réseau cible permet à des utilisateurs inconnus de **transférer les données de zone DNS**, il est facile d'obtenir les informations DNS. La requête renvoie une **structure d'enregistrements** contenant les informations sur le DNS cible ; ces enregistrements révèlent la **localisation et les types de serveurs**.

SecurityTrails

(securitytrails.com) — outil avancé d'énumération DNS capable de créer une **carte DNS** du réseau du domaine cible. Il énumère les enregistrements **courants et historiques** (A, AAAA, NS, MX, SOA, TXT) et tous les **sous-domaines existants** par **brute-force**.

Fierce

(github.com) — outil de reconnaissance DNS. Commandes principales :

Commande	Rôle
<code>fierce --domain certifiedhacker.com</code>	Scan de base du domaine cible
<code>fierce --domain certifiedhacker.com --subdomains write admin mail</code>	Recherche de sous-domaines spécifiques (mots-clés)
<code>fierce --domain certifiedhacker.com --subdomains mail --traverse 10</code>	Recherche de blocs contigus d'IP dans une plage de 10 (<code>--traverse 10</code>)
<code>fierce --domain certifiedhacker.com --subdomains mail --connect</code>	Tente une connexion HTTP sur les domaines découverts
<code>fierce --domain certifiedhacker.com --wide</code>	Scan complet détaillé de tous les enregistrements découverts

Fierce permet d'identifier les **espaces IP non contigus** et les hostnames liés aux domaines/sous-domaines, de créer un **environnement réseau** et d'identifier les cibles potentielles d'exploitation.

6.4 Le DNS lookup avec l'IA

Prompt : « *Install and use DNSRecon to perform DNS enumeration on the target domain www.certifiedhacker.com* » → l'IA génère :

```
sudo apt-get update && sudo apt-get install -y dnsrecon && dnsrecon -d certifiedhacker.com -t std
```

- `sudo apt-get update` : met à jour les listes de paquets ;
- `sudo apt-get install -y dnsrecon` : installe dnsrecon (réponse « oui » automatique) ;
- `dnsrecon -d certifiedhacker.com -t std` : lance l'énumération DNS standard (`-d` = domaine, `-t` = type d'énumération, ici `std`).

Résultat : SOA, NS (avec versions BIND), MX, A, TXT (SPF), et l'énumération des **enregistrements SRV** (`_caldav`, `_caldavs`, `_carddav`, `_carddavs`, `_autodiscover` ...).

6.5 Le reverse DNS lookup

- Le **DNS lookup** convertit un **nom de domaine en adresse IP** (enregistrement A).
- Le **reverse DNS lookup** convertit une **adresse IP en nom de domaine** (enregistrement PTR).
L'attaquant effectue un reverse lookup sur une plage IP pour localiser les enregistrements PTR.

Outils : **DNSRecon**, **Reverse Lookup** (`mxtoolbox.com`), **puredns**, **Reverse IP Domain Check**, **Reverse IP Lookup**.

```
dnsrecon -r 162.241.216.0-162.241.216.255
```

- `-r` : spécifie la **plage d'adresses IP** (première à dernière) pour un reverse lookup par brute force.

> Exemple résultat : chaque IP de la plage 162.241.216.0/24 est associée à un hostname (162-241-216-X.unifiedlayer.com , box533X.bluehost.com , etc.) → cartographie des hôtes du réseau cible.

7. Le footprinting réseau et email

7.1 Localiser la plage réseau (network range)

Pour faire du footprinting réseau, il faut d'abord collecter des informations de base sur la cible : **ce que fait l'organisation, qui y travaille, quel type de travail** elle effectue. Les réponses aident à identifier la **structure interne du réseau cible**.

Les plages IP privées (réservées par l'IANA)

Bloc	Préfixe CIDR
10.0.0.0 - 10.255.255.255	10/8
172.16.0.0 - 172.31.255.255	172.16/12
192.168.0.0 - 192.168.255.255	192.168/16

Obtenir des **adresses IP privées** peut être utile à l'attaquant (IP interne de la passerelle, machines internes via des DNS mal configurés).

Trouver la plage réseau via ARIN

- Utiliser la base **Whois d'ARIN** (arin.net/about/welcome/region) et entrer l'IP du serveur cible dans la zone « **Search Whois** ».
- Résultat : **Net Range** (ex. 207.46.0.0 - 207.46.255.255), **CIDR** (207.46.0.0/16), nom (MICROSOFT-GLOBAL-NET), Handle, NetType (DIRECT ALLOCATION), dates, entités liées (organisation, adresse, rôles).
- La plage réseau permet d'obtenir : la **topologie du réseau**, le **dispositif de contrôle d'accès** et l'**OS** utilisé.
- Des **serveurs DNS mal configurés** offrent une chance d'obtenir la liste des machines internes ; tracer une route vers une machine peut révéler l'**IP interne de la passerelle**.

Un seul outil ne fournit pas toutes les informations : les attaquants utilisent **plusieurs outils** pour collecter les informations réseau.

7.2 Traceroute

Le **traceroute** trace le chemin (route) que parcourent les paquets vers l'hôte cible. Il fonctionne grâce au **protocole ICMP** et au **champ TTL (Time to Live)** de l'en-tête IP.

Comment ça marche

- Le **TTL** indique le **nombre maximal de routeurs** qu'un paquet peut traverser.
- Chaque routeur **décrémente le TTL de 1** ; quand le compteur atteint **0**, le routeur **rejette le paquet** et renvoie un **message d'erreur ICMP** à l'émetteur.
- Traceroute envoie des paquets avec un TTL croissant (1, 2, 3...) et enregistre l'**IP et le nom DNS** de chaque routeur qui répond, ainsi que le **temps aller-retour** (RTT). À l'arrivée, la réponse ICMP ping normale est renvoyée.

Les trois types de traceroute

Type	Système	Commande
ICMP traceroute	Windows (par défaut)	<code>tracert 216.239.36.10</code>
TCP traceroute (Layer 4)	Linux — quand l'ICMP est bloqué par les appareils du réseau	<code>sudo tcptraceroute www.google.com</code>
UDP traceroute	Linux (utilitaire intégré)	<code>traceroute www.google.com</code>

Beaucoup d'appareils bloquent les messages ICMP : dans ce cas, on utilise le traceroute **TCP ou UDP** (traceroute de couche 4).

Le traceroute révèle : le **nombre de routeurs** traversés, le **temps aller-retour** entre deux routeurs, les **noms des routeurs** et leur **affiliation réseau** (si entrées DNS), et la **localisation géographique**.

Traceroute avec l'IA

Prompt : « Perform network tracerouting to discover the routers on the path to a target host `www.certifiedhacker.com` » → l'IA génère :

```
traceroute www.certifiedhacker.com
```

7.3 L'analyse de traceroute

En combinant plusieurs traceroutes, l'attaquant peut **localiser la position d'un saut** dans le réseau cible. Exemple :

```
traceroute 1.10.20.10 → avant-dernier saut : 1.10.10.50
traceroute 1.10.20.15 → avant-dernier saut : 1.10.10.50
traceroute 1.10.20.10 → avant-avant-dernier saut : 1.10.10.1
```

Analyse : `1.10.10.1` est le **routeur** d'entrée, `1.10.10.50` est le **bastion host / pare-feu** devant la zone DMZ qui abrite le **serveur web** (`1.10.20.10`) et le **serveur mail** (`1.10.20.15`). L'attaquant identifie ainsi les **périphériques intermédiaires** (routeurs, pare-feux) entre la source et la destination.

7.4 Les outils de traceroute

- **NetScanTools Pro** (`netscantools.com`) : trace le chemin des paquets (LAN ou Internet), offre les méthodes **ICMP, UDP ou TCP**, identifie les périphériques intermédiaires et localise le **pays attribué à chaque adresse IPv4** de chaque saut.
- **PingPlotter** (`pingplotter.com`) : collecte des données de traceroute (**ICMP, UDP, TCP**), découvre automatiquement les sauts, suit la **latence et la perte de paquets** dans le temps, visualise les données en graphes. Aide à identifier les **goulots d'étranglement de bande passante**, les **interférences WiFi** et les **pannes matérielles**.
- **Traceroute NG, tracert.**

Fonctionnalités courantes : traceroutes hop-by-hop, ping plotting, reverse tracing, port probing, analyse historique, détection de problèmes réseau, rapport de perte de paquets, analyse de métriques de performance, reverse DNS, surveillance de la performance réseau.

7.5 Le tracking des communications email

L'**email tracking** surveille les messages email d'un utilisateur via des enregistrements **horodatés numériquement** qui révèlent **quand** la cible reçoit et ouvre un email.

Informations collectées sur la victime : - **IP du système du destinataire** : suivi de l'adresse IP ; - **Géolocalisation** : position estimée sur la carte, distance depuis la position de l'attaquant ; - **Réception et lecture** : notification quand l'email est reçu/lu ; - **Durée de lecture** ; - **Détection de proxy** : type de serveur utilisé par le destinataire ; - **Liens** : vérification que les liens envoyés ont été cliqués ; - **OS et navigateur** : pour trouver des failles dans ces versions ; - **Transfert** : savoir si l'email a été transféré à quelqu'un ; - **Type d'appareil** : ordinateur, mobile, portable ; - **Chemin parcouru** : trajet via les agents de transfert de mail (MTA).

Outils : **IP2LOCATION's Email Header Tracer**, **MxToolbox**, **DNS Checker Email Header Analyzer**, **Social Catfish**.

7.6 Collecter des informations depuis l'en-tête email

Un **en-tête email** contient les détails de l'expéditeur, les informations de routage, le schéma d'adressage, la date, le sujet et le destinataire. Il permet de tracer le **chemin de routage** pris par un email avant d'être livré.

Informations contenues : - Serveur de mail de l'**expéditeur** ; - Date et heure de réception par les serveurs email de l'expéditeur ; - **Système d'authentification** utilisé par le serveur mail de l'expéditeur ; - Date et heure d'envoi du message ; - **Numéro unique** attribué par mx.google.com pour identifier le message ; - **Nom complet** de l'expéditeur ; - **Adresse IP de l'expéditeur** et adresse d'expédition.

Clients email courants : **eM Client**, **SmarterMail Webmail**, **Mailbird**, **Outlook**, **Hiri**, **Apple Mail**, **Mozilla Thunderbird**, **ProtonMail**, **Spike**, **AOL Mail**, **Claws Mail**, **Tuta**.

7.7 Les outils de tracking email

- **eMailTrackerPro** (emailtrackerpro.com) : analyse les en-têtes email et extrait la **localisation géographique** de l'expéditeur, son **IP**, etc. Permet de revoir les traces en les **enregistrant**. Détecte aussi si le système fait tourner un serveur mail (port 25).
 - **IP2LOCATION's Email Header Tracer** (ip2location.com) : service **open-source** pour analyser et tracer le chemin email à partir des en-têtes : retrouve la **localisation cible** et les **serveurs mail de passage** via les adresses IP de l'en-tête (pays, région et ville, coordonnées, ISP, fuseau horaire, domaine, ASN...).
 - **MxToolbox**, **Social Catfish**, **Holehe**, **DNS Checker Email Header Analyzer**.
-

8. Le footprinting via l'ingénierie sociale

8.1 Le concept

L'**ingénierie sociale** est l'**art d'exploiter le comportement humain** pour extraire des informations confidentielles. Les ingénieurs sociaux comptent sur le fait que les gens sont **inconscients de la valeur** de leurs informations et **négligents** pour les protéger.

C'est un **processus non technique** : l'attaquant induit une personne en erreur pour qu'elle fournisse des informations confidentielles **sans le savoir**. Pour réussir, l'attaquant doit d'abord **gagner la confiance** d'un utilisateur autorisé, puis l'amener à révéler les informations.

Objectifs : accès non autorisé au système, **vol d'identité**, **espionnage industriel**, intrusion réseau, fraude...

Informations recherchées : - Détails de **carte de crédit** et **numéro de sécurité sociale (SSN)** ; - Noms d'utilisateur et **mots de passe** ; - **Produits de sécurité** en place ; - **OS et versions logicielles** ; - **Plan du réseau** ; - **Adresses IP et noms des serveurs**.

Techniques : **eavesdropping**, **shoulder surfing**, **dumpster diving**, **impersonation**, **tailgating**, **autorisation de tiers (third-party authorization)**, **piggybacking**, **reverse social engineering**...

8.2 Collecter des informations par l'ingénierie sociale sur les réseaux sociaux

Les réseaux sociaux (LinkedIn, Facebook, Instagram, Twitter, Pinterest, YouTube) sont **ouverts à tous**. L'attaquant peut : - Parcourir les **profils publics** ; - Créer un **faux profil** pour se faire passer pour un utilisateur authentique ; - Envoyer une **demande d'ami** depuis un faux compte : si elle est acceptée, il accède même aux **pages restreintes** de la cible ; - Recueillir les informations **postées par les individus** (aucune barrière d'accès aux pages publiques).

Ce que font les utilisateurs / ce que l'attaquant obtient

Ce que fait l'utilisateur	Ce que l'attaquant obtient
Maintient son profil	Coordonnées, localisation, informations liées
Se connecte à des amis, discute	Liste d'amis, informations sur les amis
Partage photos et vidéos	Identité des membres de la famille, intérêts
Joue à des jeux, rejoint des groupes	Intérêts
Crée des événements	Activités

Ce que font les organisations / ce que l'attaquant obtient

Ce que fait l'organisation	Ce que l'attaquant obtient
Sondages utilisateurs	Stratégies commerciales
Promotion de produits	Profil produit
Support utilisateur	Ingénierie sociale
Recrutement	Informations plateforme/technologie
Vérification de fond pour embaucher	Type d'activité

8.3 Les techniques de collecte d'informations

Technique	Description
Eavesdropping (écoute clandestine)	Interception d'une communication sous toute forme : audio, vidéo, texte (messages instantanés, transmissions fax, conversations téléphoniques)
Shoulder surfing (observation par-dessus l'épaule)	L'attaquant observe secrètement la cible (touches saisies) pour obtenir mots de passe, PIN , numéros de compte, informations de carte de crédit ... Particulièrement efficace dans les lieux bondés
Dumpster diving (fouille de poubelles)	Aussi appelé « trashing » : fouiller les poubelles de la société (factures téléphoniques, coordonnées, informations financières, impressions de code source, notes autocollantes sur les bureaux, poubelles des imprimantes, poubelles des ATM)
Impersonation (usurpation d'identité)	L'attaquant se fait passer pour une personne légitime ou autorisée (livreur, concierge, homme d'affaires, client, technicien, visiteur) en personne ou via le téléphone pour tromper les cibles et leur soutirer des informations

9. Automatiser le footprinting avec des outils avancés et l'IA

Les outils de footprinting collectent : **localisation IP**, **informations de routage**, informations commerciales, adresse, téléphone, numéro de sécurité sociale, détails sur la **source d'un email ou d'un fichier**, informations **DNS** et **domaine**.

9.1 Maltego

(maltego.com) — outil automatisé pour déterminer les **relations et liens réels** entre personnes, groupes de personnes, organisations, sites web, **infrastructure Internet**, documents...

- Différentes **entités** permettent d'obtenir : adresses email, liste de numéros de téléphone, infrastructure Internet de la cible (domaines, noms DNS, Netblocks, adresses IP).
- Utilisation : ajouter une entité « **Website** », la renommer avec le **domaine cible** (ex. `certifiedhacker.com`), puis exécuter les transformées pour obtenir les emails et téléphones associés.

9.2 Recon-ng

(github.com) — **framework de reconnaissance web** avec modules indépendants et interaction avec une base de données : il fournit un environnement dans lequel on peut mener une **reconnaissance open source basée sur le web**.

- Module `recon/domains-hosts/brute_hosts` : extrait une **liste d'hôtes** associés à l'URL cible (par brute force sur les noms).
- Commandes : `bash modules load recon/domains-hosts/brute_hosts run`
- Autres modules : `recon/domains-domains/brute_suffix`, `recon/repositories-vulnerabilities/github_dorks` ...

9.3 FOCA

FOCA (Fingerprinting Organizations with Collected Archives) (elevenpaths.com) — outil utilisé surtout pour trouver les **métadonnées et informations cachées** dans les documents qu'il scanne : **Microsoft Office, Open Office, PDF**.

Fonctionnalités : - **Web Search** : recherche d'hôtes et de domaines via les URL liées au domaine principal ; - **DNS Search** : vérifie les hostnames configurés dans les serveurs **NS, MX, SPF** ; - **IP Resolution** : résout chaque hostname via le DNS (y compris le DNS **interne** de l'organisation) pour obtenir les IP ; - **PTR Scanning** : scan des logs PTR pour trouver d'autres serveurs dans le même segment d'une adresse ; - **Bing IP** : recherche de nouveaux domaines associés à chaque IP découverte ; - **Common Names** : attaque par **dictionnaire** contre le DNS.

Il affiche aussi : **domaines réseau, rôles, vulnérabilités** et **métadonnées** du domaine cible.

9.4 subfinder

(github.com) — outil de **découverte de sous-domaines** via des **sources passives en ligne**. Supporte plusieurs formats de sortie (**JSON, fichier, stdout**).

```
subfinder -d certifiedhacker.com
```

Résultat : liste des sous-domaines valides (www, autodiscover, blog, cpanel, demo, ...).

9.5 OSINT Framework

(osintframework.com) — framework open source de **collecte de renseignements**, focalisé sur les outils et ressources **gratuits**. Interface web simple listant les outils OSINT par catégorie, sous forme d'**arbre OSINT**.

Indicateurs utilisés dans la liste : - **(T)** : lien vers un outil à **installer et exécuter localement** ; - **(D)** : **Google Dork** ; - **(R)** : **inscription requise** ; - **(M)** : URL contenant le terme de recherche ; **l'URL elle-même doit être éditée manuellement**.

Catégories : domaines (Whois, DNS, sous-domaines), emails, réseaux sociaux, métadonnées, archives, dark web, menaces, etc.

9.6 Recon-Dog

(github.com) — outil **tout-en-un** de collecte d'informations de base, utilisant des **APIs**. Fonctionnalités : - **Censys** : masse d'informations sur une adresse IP ; - **NS lookup** : recherche de serveurs de noms ; - **Port scan** : scan des ports TCP les plus courants ; - **Detect CMS** : détection de **400+** systèmes de gestion de contenu ; - **Whois lookup** ; - **Detect honeypot** : utilise shodan.io pour vérifier si la cible est un honeypot ; - **Find subdomains** : via findsubdomains.com ; - **Reverse IP lookup** : domaines associés à une adresse IP ; - **Detect technologies** : via wappalyzer.com (100+ technologies) ; - **All** : exécute tous les utilitaires contre la cible.

9.7 BillCipher

(github.com) — outil de collecte d'informations pour un **site web ou une adresse IP**. Fonctionne sur tout OS supportant **Python 2, Python 3 et Ruby**.

Options : **DNS lookup, Whois lookup, port scanning, zone transfer, host finder, reverse IP lookup**, GeoIP lookup, Subnet lookup, Page Links, HTTP Header, IP-Locator, Find Shared DNS Servers, Get Robots.txt, Host DNS Finder, Email Gathering (Infoga), Subdomain listing (Sublist3r), Find Admin login site (Breacher), Check and Bypass CloudFlare (Hatcloud), Website Copier (httrack), Host Info Scanner (Whatweb).

9.8 Autres outils de footprinting

Sudomy, theHarvester, whatweb, Raccoon, Orb, Web Check (web-check.xyz), **OSINT.SH** (osint.sh).

9.9 Les outils OSINT alimentés par l'IA

L'IA a révolutionné l'**OSINT** en renforçant la collecte, l'analyse et la prédiction de données : elle automatise le traitement, extrait des informations pertinentes et fournit des renseignements exploitables plus efficacement que les méthodes traditionnelles.

Cas d'usage de l'IA en OSINT

- **Web Scraping** : collecte automatisée de données (médias sociaux, blogs, forums, bases du deep web) ; les modèles de ML automatisent l'extraction d'informations spécifiques (commentaires, réponses).
- **Pattern Recognition** : identification d'entités (noms, entreprises, adresses, emails, téléphones) dans de grands ensembles de données et analyse des relations entre elles.
- **Content Summarization** : algorithmes **NLP** pour résumer de gros volumes de données (ex. extraire des noms de sociétés d'un ensemble de PDF de centaines de pages).

- **Sentiment Analysis** : interprétation des émotions humaines via l'analyse de texte (posts et commentaires) ; prédiction du comportement des consommateurs.
- **Image Recognition** : vision par ordinateur — reconnaissance faciale et suivi de personnes, analyse de métadonnées, reverse image search amélioré, **détection de deepfakes**.
- **AI Detection** : détection du contenu généré par d'autres IA (activités malveillantes facilitées par l'IA).

Avantages de l'intégration de l'IA en OSINT

- **Efficacité améliorée** : automatisation du web scraping et de l'extraction de données ;
- **Portée élargie** : analyse de vastes données du **surface web, deep web et dark web** ;
- **Visibilité renforcée** : connexion de milliards de points de données en réseaux d'informations cohérents, présentés via des interfaces graphiques ;
- **Sécurité** : investigations menées sans implication humaine directe dans des environnements dangereux (dark web).

Outils IA

Outil	Rôle
Taranis AI (taranis.ai)	Collecte d'articles de news non structurés, enrichis par IA et NLP ; sorties multi-format (rapports, PDF) et publication
Oss Insight (ossinsight.io)	Analyse de l'écosystème GitHub (5+ milliards d'événements) : exploration de données propulsée par GPT , analytics de domaines techniques (frameworks web, IA, Web3), analytics développeurs et dépôts (stars, forks, commits)
DorkGPT (dorkgpt.com)	Génère et affine des Google Dorks grâce aux modèles GPT
DorkGenius (dorkgenius.com)	Automatise le Google Dorking (fichiers cachés, répertoires, infos sensibles, vulnérabilités)
Google Word Sniper (googlewordsniper.eu)	Affine les requêtes Google pour des résultats plus efficaces
Cylect.io	Intègre de multiples bases de données dans une interface utilisateur pour des investigations OSINT rapides
ChatPDF (chatpdf.com)	Analyse et extraction d'informations depuis des PDF via une interface conversationnelle
Bardeen.ai	Automatisation de la collecte et de l'analyse de données en ligne
DarkGPT (github.com/luijait/DarkGPT)	Assistant IA (GPT-4-200K) interrogeant les bases de données fuitées
PenLink Cobwebs (cobwebs.com)	Collecte, traitement et visualisation d'informations pour les investigations cyber
Explore AI (exploreai.vercel.app)	Moteur de recherche YouTube propulsé par l'IA
AnyPicker (app.anypicker.com)	Extraction de données de sites web sans code , scraping multi-pages, aperçu en temps réel

9.10 Créer et exécuter un script Python personnalisé avec l'IA

Un attaquant peut demander à ChatGPT de créer un script Python qui automatise une série de commandes de footprinting web. Prompt type :

« Develop a Python script which will accept the domain name `www.microsoft.com` as input and execute a series of website footprinting commands, including DNS lookups, WHOIS records retrieval, email enumeration, and more, to gather information about the target domain »

Script généré (`website_footprinting.py`) :

```
import subprocess

def dns_lookup(domain):
    return subprocess.getoutput(f"dig {domain} ANY +noall +answer")

def whois_lookup(domain):
    return subprocess.getoutput(f"whois {domain}")

def email_enumeration(domain):
    return subprocess.getoutput(f"theHarvester -d {domain} -b all -l 100")

def run_footprinting(domain):
    print("Performing DNS Lookup...")
    dns_info = dns_lookup(domain)
    print(dns_info)
    print("\nPerforming Whois Lookup...")
    whois_info = whois_lookup(domain)
    print(whois_info)
    print("\nEnumerating Emails...")
    emails = email_enumeration(domain)
    print(emails)

domain = 'www.microsoft.com'
run_footprinting(domain)
```

- `dns_lookup(domain)` : effectue un DNS lookup via `dig` ;
- `whois_lookup(domain)` : récupère les enregistrements WHOIS via `whois` ;
- `email_enumeration(domain)` : énumère les emails via **theHarvester** ;
- `run_footprinting(domain)` : exécute la série de commandes.

Exécution :

```
python3 website_footprinting.py
```

Résultat : CNAME et IP de `www.microsoft.com`, enregistrement Whois, emails et hôtes trouvés, et 172 IPs associées.

10. Les contre-mesures du footprinting

Les **contre-mesures du footprinting** sont les mesures ou actions prises pour **prévenir ou compenser la divulgation d'informations**.

10.1 La liste complète des contre-mesures

Gestion de l'information publiée : 1. **Limiter la quantité d'informations** publiées sur un site web ou sur Internet ; 2. Ne pas révéler d'informations critiques dans les **communiqués de presse, rapports annuels, catalogues produits**, etc. ; 3. Utiliser les **techniques de footprinting** pour découvrir et **supprimer toute information sensible** accessible publiquement ; 4. **Empêcher les moteurs de recherche de mettre en cache** une page web et utiliser des **services d'enregistrement anonymes** ; 5. Placer les **documents critiques** (plans d'affaires, documents propriétaires) **hors ligne** pour empêcher leur exploitation ; 6. S'assurer qu'**aucune information critique** (plans stratégiques, informations produits, projections de ventes) n'est affichée sur les **tableaux d'affichage ou les murs** ; 7. **Demander à archive.org** de supprimer l'historique du site web de la base d'archives ; 8. **Garder le profil du nom de domaine privé**.

Serveurs web et infrastructure : 9. **Configurer les serveurs web** pour éviter les **fuites d'informations** ; 10. **Désactiver les listes de répertoires** sur les serveurs web ; 11. Configurer **IIS** pour éviter la divulgation d'informations via le **banner grabbing** ; 12. **Ne pas activer les protocoles non requis** ; 13. Toujours utiliser des **filtres TCP/IP et IPsec** pour la défense en profondeur ; 14. **Masquer l'adresse IP** en implémentant un **VPN** ou en gardant le serveur derrière un **proxy sécurisé** ; 15. **Séparer DNS interne/externe** ou utiliser un **split DNS**, et **restreindre les transferts de zone** aux serveurs autorisés ; 16. **Désactiver ou supprimer les comptes** des employés partis de l'organisation ; 17. **Configurer les serveurs mail** pour ignorer les emails de personnes anonymes ; 18. Déployer des **honeypots ou honeynets** dans le réseau pour attirer et détecter les attaquants et **détourner les footprinteurs des systèmes critiques**.

Politiques, formation et personnel : 19. **Restreindre l'accès des employés aux réseaux sociaux** depuis le réseau de l'organisation ; 20. **Éduquer les employés** à utiliser des **pseudonymes** sur les blogs, groupes et forums ; 21. **Développer et appliquer des politiques de sécurité** (sécurité de l'information, mots de passe) pour réguler les informations que les employés peuvent révéler à des tiers ; 22. **Former les employés** à contrer les **techniques et attaques d'ingénierie sociale** ; 23. Mener **périodiquement des formations de sensibilisation à la sécurité** pour éduquer les employés sur les pièges et risques de l'ingénierie sociale ; 24. **Assainir les détails fournis aux registres Internet** (registrars) pour masquer les **coordonnées directes** de l'organisation ; 25. **Opter pour des services de confidentialité** sur la base de données Whois ; 26. **Éviter le cross-linking au niveau domaine** pour les actifs critiques.

Sécurité technique et vie privée : 27. Implémenter l'**authentification multifacteur (MFA)** ; 28. **Chiffrer et protéger par mot de passe** les informations sensibles ; 29. Implémenter des **captchas et du rate limiting** sur les services publics pour empêcher les outils automatisés de collecter les informations à un rythme rapide ; 30. **Désactiver le géo-tagging** sur les caméras pour empêcher le suivi géolocalisé ; 31. **Éviter de révéler sa localisation ou ses projets de voyage** sur les réseaux sociaux ; 32. **Désactiver l'accès géolocalisé sur tous les appareils mobiles** lorsque ce n'est pas nécessaire.

> Points clés à retenir pour l'examen : limiter l'information publiée, empêcher le cache des moteurs de recherche, split DNS + restriction des transferts de zone, pseudonymes, services de confidentialité Whois, désactivation du géo-tagging, suppression des comptes des anciens employés, honeypots, formation à la sécurité.

11. Aide-mémoire final pour l'examen

11.1 Concepts fondamentaux

- **Footprinting** = phase préparatoire de collecte d'informations (première étape de l'évaluation de la posture de sécurité).
- **Passif** : aucune interaction directe, OSINT, l'attaquant n'est pas détecté.
- **Actif** : interaction directe (interrogation DNS, ingénierie sociale, scan réseau/ports, énumération), peut être détecté.
- Informations : **organisationnelles**, **réseau** (domaines, NetBlocks, IP, Whois, DNS), **système** (OS, localisation des serveurs, emails, technologies web).
- Menaces : ingénierie sociale, attaques système/réseau, fuite d'informations, perte de vie privée, espionnage concurrentiel.
- Footprint = « **blueprint** du profil de sécurité » de l'organisation.

11.2 Moteurs de recherche (Google hacking)

- Syntaxe : `opérateur: terme` (sans espace).
- Opérateurs à connaître : `site:`, `allinurl:`, `inurl:`, `intext:`, `allintitle:`, `intitle:`, `inanchor:`, `allinanchor:`, `cache:`, `link:`, `related:`, `info:`, `location:`, `filetype:`, `source:`, `phonebook:`, `before:`, `after:`.
- **link:** ne peut pas être combinée avec une recherche par mot-clé normal.
- **GHDB** (`exploit-db.com/google-hacking-database`) + **SearchSploit** (version locale, utilisable hors-ligne / air-gapped).
- **Shodan** : détection d'appareils et réseaux vulnérables (IoT, VoIP, VPN) ; **Censys**, **ZoomEye**.
- Moteurs méta (Startpage, MetaGer, eTools.ch), FTP (NAPALM, Mamont, Globalfilesearch), vidéo (YouTube + YouTube Metadata/DataViewer/MW Metadata), reverse image (TinEye), IoT.
- IA : `sgpt --chat footprint --shell "..."` + pipelines `lynx --dump`.

11.3 Services de recherche sur Internet

- TLD/sous-domaines : **Netcraft**, **DNSdumpster**, Pentest-Tools, `site:microsoft.com -inurl:www`, **Sublist3r**.
- **archive.org** (Wayback Machine) + **Photon** : versions supprimées du site.
- Recherche de personnes : Spokeo, Intelius, pipl, BeenVerified, Whitepages, PeekYou ; sites d'emploi : **Dice**, **LinkedIn**, **Glassdoor** (technologie interne).
- Dark web : **Tor Browser** (rebond de l'IP, VPN par défaut), ExoneraTor, OnionLand ; sites `.onion`.
- **OS fingerprinting** : Netcraft, Shodan, Censys.
- Renseignement concurrentiel : EDGAR (SEC), D&B Hoovers, LexisNexis, Business Wire, Factiva, MarketWatch, USPTO, SEMRush, SimilarWeb, SERanking ; approches **directe** (salons, social engineering) et **indirecte**.
- Autres : Google Earth/Maps/Wikimapia, Google Finance/MSN Money/Yahoo Finance, opencorporates/Crunchbase, Google Alerts/X Alerts/Giga Alerts, Mention/ReviewPush/Reputology (ORM), Google Groups/LinkedIn Groups, GitHub/GitLab + **Recon-ng**.

11.4 Réseaux sociaux

- Footprinting réseaux sociaux = collecte d'infos **disponibles** (vs social engineering = **tromper**).

- theHarvester : `theHarvester -d <domain> -l <nb> -b <source>` (linkedin, baidu, google, bing...) → employés, postes, emails.
- Outils : **BuzzSumo** (contenu le plus partagé), **Google Trends**, **Hashatit**, **Ubersuggest** ; **Sherlock** (nom d'utilisateur sur de nombreux sites, `sherlock <user> --output <fichier>`), **Social Searcher** (recherche en temps réel, analytics, sentiment).

11.5 Whois

- Protocole de requête/réponse sur le **port 43 (TCP)**.
- Bases maintenues par les **RIR** : **ARIN** (Amérique du Nord), **AFRINIC** (Afrique), **APNIC** (Asie-Pacifique), **RIPE NCC** (Europe), **LACNIC** (Amérique latine/Caraïbes).
- Modèles : **Thick** (distribué, toutes les infos), **Thin** (centralisé, nom du serveur Whois du registrar), **décentralisé**.
- Infos : domaine, registrar, contacts propriétaire, name servers, NetRange, création, expiration, dernière mise à jour, statut, IP.
- Outils : whois.domaintools.com, tamos.com, **Batch IP Converter** (sabsoft.com, IDN + IPv6), Whois Domain Lookup, Active Whois.
- **Géolocalisation IP** : IP2Location, IP Location Finder (pays, ville, ISP, ASN, fuseau, opérateur mobile).

11.6 DNS

- Objectif : serveurs DNS, enregistrements, types de serveurs → hôtes clés du réseau.
- Enregistrements : **A** (IPv4), **AAAA** (IPv6), **MX** (mail), **NS** (name server), **CNAME** (alias), **SOA** (autorité), **SRV** (services), **PTR** (IP→hostname), **RP** (personne responsable), **HINFO** (CPU + OS), **TXT**.
- Outils : **SecurityTrails** (records actuels + historiques, sous-domaines par brute-force), **Fierce** (`--domain`, `--subdomains`, `--traverse`, `--connect`, `--wide`), **DNSRecon** (`-d <domain> -t std, -r <plage>`), DNSChecker, zdns, DNSdumpster.
- **Reverse DNS** : IP → nom de domaine (PTR) ; outils DNSRecon, Reverse Lookup (mxtoolbox), puredns, Reverse IP Domain Check, Reverse IP Lookup.

11.7 Réseau et email

- **Plages IP privées (IANA)** : `10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`.
- Plage réseau via la base **Whois d'ARIN** (Net Range, CIDR, NetType, organisation).
- **Traceroute** : protocole **ICMP** + champ **TTL** de l'en-tête IP ; chaque routeur décrémente le TTL de 1, à 0 → erreur ICMP.
- Windows : `tracert <IP>` (ICMP) ; Linux : `traceroute <domain>` (UDP) ; TCP (Layer 4) : `sudo tcptraceroute <domain>`.
- Outils : **NetScanTools Pro**, **PingPlotter**, **Traceroute NG**.
- **Tracking email** : IP du destinataire, géolocalisation, lecture, durée de lecture, proxy, liens, OS/navigateur, transfert, type d'appareil, chemin parcouru.
- **En-têtes email** : serveur mail de l'expéditeur, dates/heures, authentification, numéro unique, nom complet, IP de l'expéditeur.
- Outils : **eMailTrackerPro**, **IP2LOCATION's Email Header Tracer**, MxToolbox, Social Catfish, Holehe, DNS Checker Email Header Analyzer.

11.8 Ingénierie sociale

- Exploitation du **comportement humain** pour extraire des informations confidentielles (processus non technique).

- Techniques : **eavesdropping** (interception), **shoulder surfing** (observation par-dessus l'épaule), **dumpster diving** (fouille de poubelles / trashing), **impersonation** (usurpation d'identité), plus tailgating, third-party authorization, piggybacking, reverse social engineering.
- Faux profil sur les réseaux sociaux + demande d'ami → accès aux pages restreintes.

11.9 Outils et IA

- **Maltego** : relations entre entités (domaines, DNS, Netblocks, IP, emails, téléphones).
- **Recon-ng** : framework de reconnaissance web (modules `brute_hosts`, `github_dorks`...).
- **FOCA** : métadonnées et infos cachées dans les documents (Office, PDF) ; Web Search, DNS Search, IP Resolution, PTR Scanning, Bing IP, Common Names.
- **subfinder** : sous-domaines passifs ; **OSINT Framework** : indicateurs (T) local, (D) dork, (R) inscription, (M) édition manuelle.
- **Recon-Dog** (tout-en-un, APIs), **BillCipher** (Python 2/3, Ruby), **Sudomy**, **theHarvester**, **whatweb**, **Raccoon**, **Orb**, **Web Check**, **OSINT.SH**.
- **IA en OSINT** : web scraping, pattern recognition, résumé NLP, sentiment analysis, image recognition, AI detection.
- Avantages : efficacité, portée (surface/deep/dark web), visibilité, sécurité.
- Outils IA : Taranis AI, Oss Insight (GitHub, GPT), DorkGPT, DorkGenius, Google Word Sniper, Cylect.io, ChatPDF, Bardeen.ai, DarkGPT, PenLink Cobwebs, Explore AI, AnyPicker.
- **Script Python avec IA** : `dig {domain} ANY +noall +answer, whois {domain}, theHarvester -d {domain} -b all -l 100` → `python3 website_footprinting.py`.

11.10 Contre-mesures (essentiels)

- Limiter les informations publiées ; supprimer les infos sensibles accessibles ; empêcher le **cache** des moteurs de recherche ; enregistrement anonyme.
- Restreindre les réseaux sociaux ; **pseudonymes** sur blogs/forums ; former à l'ingénierie sociale ; politiques de sécurité ; MFA.
- **Split DNS** + transferts de zone restreints ; désactiver les listes de répertoires ; filtrer TCP/IP + IPsec ; cacher l'IP (VPN/proxy) ; désactiver les protocoles non requis ; configurer IIS (banner grabbing).
- Services de confidentialité Whois ; assainir les données des registrars ; supprimer les comptes des anciens employés ; **désactiver le géo-tagging** ; ne pas révéler sa localisation ; honeypots/honeynets ; demander la suppression de l'historique sur **archive.org**.

CEH v13 Dump — Module 02 : Footprinting and Reconnaissance

Exam-Style Practice Questions (312-50) — With Answer Key

60 multiple-choice questions based on Module 02 content. Answer key at the end (page 8).

Questions

Part A — Footprinting Concepts (Q1-Q14)

- Q1.** In the CEH methodology, **footprinting and reconnaissance** is best defined as: - A) The phase where the attacker actively exploits system vulnerabilities - B) The first/preparatory phase during which the attacker gathers as much information as possible about the target before launching an attack - C) The final phase where the attacker erases all traces of the attack - D) The phase where the attacker installs backdoors for persistent access
- Q2.** Which statement best describes **passive footprinting**? - A) It involves direct interaction with the target and can be detected - B) It collects information without direct interaction, so the target is unaware of the collection - C) It requires scanning every port of the target network - D) It is only performed after an active scan
- Q3.** Which of the following is an **active footprinting** activity? - A) Social networking sites - B) DNS interrogation - C) archive.org - D) Whois lookup
- Q4.** **OSINT** stands for: - A) Open Source Information Networks and Tools - B) Open-Source Intelligence - C) Online Security Intelligence Techniques - D) Off-Site Intelligence
- Q5.** Which of the following belongs to the **organizational information** gathered by footprinting? - A) Details of employees (names, contact addresses, job functions) - B) IP addresses of reachable systems - C) NetBlocks of the target - D) DNS records
- Q6.** Which information category includes **domains, sub-domains, NetBlocks, and network topology**? - A) System information - B) Organizational information - C) Network information - D) Personal information
- Q7.** The **operating systems of the web servers** of the target are part of: - A) Network information - B) Organizational information - C) System information - D) Financial information
- Q8.** The threat of **competitive espionage** refers to: - A) Employees leaking passwords through social engineering - B) Competitors gathering sensitive data to launch similar products, alter prices, and weaken the target's position - C) Loss of privacy due to privilege escalation - D) Attackers selling stolen data for profit
- Q9.** A detailed footprint provides a: - A) Blueprint of the organization's security profile - B) Complete list of the organization's customers - C) Backup of the target's databases - D) List of all employees' salaries
- Q10.** Passive footprinting is **technically difficult** because: - A) It requires physical access to the target premises - B) No active traffic is sent toward the target, so only archived and stored information is collected - C) The target blocks all search engines - D) It requires expensive commercial tools
- Q11.** Which of the following is a **passive footprinting** technique? - A) DNS interrogation - B) Traceroute - C) Social networking sites - D) Email tracking

Q12. Which threat is enabled when hackers collect information through **persuasion** from willing employees, without any technical intrusion? - A) Information leakage - B) Social engineering - C) Loss of privacy - D) Competitive espionage

Q13. According to the footprinting methodology, which sequence correctly describes the passive footprinting phases? - A) Footprinting via search engines → internet research services → social networking sites - B) DNS interrogation → traceroute → email tracking - C) Whois lookup → network scanning → port scanning - D) Social engineering → eavesdropping → shoulder surfing

Q14. Which tool is commonly used to **automate footprinting tasks**? - A) NetScanTools Pro - B) Maltego - C) eMailTrackerPro - D) PingPlotter

Part B — Search Engines and Internet Research Services (Q15-Q27)

Q15. Which Google search operator returns pages containing **all the specified terms in the URL**? - A) `inurl:` - B) `allinurl:` - C) `intitle:` - D) `intext:`

Q16. The operator `site:` is used to: - A) Restrict results to a specific site or domain - B) Show the cached version of a page - C) Search for a specific file type - D) Find related sites

Q17. Which operator searches for a term within the **body** of a web page? - A) `intitle:` - B) `inanchor:` - C) `intext:` - D) `info:`

Q18. According to Google's documentation, which operator **cannot be combined** with a normal keyword search? - A) `site:` - B) `link:` - C) `filetype:` - D) `cache:`

Q19. The **Google Hacking Database (GHDB)** is a subset of: - A) Shodan - B) Exploit-DB - C) Censys - D) theHarvester

Q20. SearchSploit is particularly useful when: - A) The network is segmented or air-gapped (no Internet access) - B) The target runs on Windows only - C) Performing reverse image search - D) Tracking email communications

Q21. Shodan is a search engine mainly used to: - A) Index web pages for Google hacking - B) Detect devices (including IoT) connected to the Internet and vulnerable networks - C) Perform reverse image search - D) Track social media mentions

Q22. Which of the following tools is used for **reverse image search**? - A) TinEye - B) Startpage - C) NAPALM - D) FileZilla

Q23. Which of the following are **FTP search engines**? - A) Startpage, MetaGer, eTools.ch - B) NAPALM FTP Indexer, FreewareWeb, Mamont - C) BuzzSumo, Ubersuggest, Hashatit - D) Spokeo, Intelius, pip!

Q24. Meta search engines such as Startpage and MetaGer: - A) Maintain their own index of web pages - B) Send the query to several third-party engines and mask the user's IP address - C) Only search for FTP files - D) Only index IoT devices

Q25. The **Tor Browser** helps an attacker on the dark web by: - A) Encrypting the target's website database - B) Acting as a VPN by default and bouncing the IP address through multiple servers - C) Removing all traces from search engine caches - D) Automatically cracking passwords

Q26. The **Internet Archive Wayback Machine (archive.org)** allows an attacker to: - A) Retrieve information that has been deleted from the target's website - B) Bypass the target's firewall - C) Perform reverse DNS lookups - D) Enumerate LinkedIn employees

Q27. Which tools can be used for **OS fingerprinting** (determining the target's operating system)? - A) Netcraft, Shodan, Censys - B) Spokeo, pip!, PeekYou - C) Startpage, MetaGer, eTools.ch - D) Maltego, FOCA, Recon-ng

Part C — Social Networking Sites, Whois and DNS (Q28-Q42)

Q28. Footprinting through **social networking sites** differs from social engineering because the attacker: - A) Tricks people into revealing information - B) Gathers information that is already available on those sites - C) Physically enters the target's premises - D) Sends phishing emails to employees

Q29. Which tool is used to **enumerate employees of the target company on LinkedIn** along with their job titles? - A) Sherlock - B) theHarvester - C) BuzzSumo - D) Social Searcher

Q30. Sherlock is a tool used to: - A) Track the most shared content across social networks - B) Search a target username across a vast number of social networking sites - C) Enumerate DNS records - D) Analyze email headers

Q31. BuzzSumo allows an attacker to: - A) Find the most shared content for a topic, author, or domain across major social networks - B) Perform Whois lookups - C) Track email delivery - D) Scan network ports

Q32. The **Whois** protocol listens on which port? - A) Port 53 (TCP) - B) Port 43 (TCP) - C) Port 25 (TCP) - D) Port 80 (TCP)

Q33. Which Regional Internet Registry (RIR) covers **Europe**? - A) ARIN - B) APNIC - C) RIPE NCC - D) LACNIC

Q34. In the **Thin Whois (centralized) model**: - A) All Whois information from all registrars is stored in one place - B) Only the name of the Whois server of the registrar of a domain is stored - C) Multiple independent entities manage the Whois database - D) Whois information is encrypted

Q35. A **Whois lookup** returns information such as: - A) NetRange, creation date, name servers, and registrar details - B) The full source code of the target website - C) The target's internal network topology - D) The employees' passwords

Q36. IP geolocation lookup tools such as IP2Location reveal: - A) The country, city, ISP, and timezone of an IP address - B) The target's DNS zone transfer - C) The target's browsing history - D) The encryption keys of the target

Q37. Which DNS record points to a host's **IPv6 address**? - A) A - B) MX - C) AAAA - D) PTR

Q38. Which DNS record points to the domain's **mail server**? - A) NS - B) MX - C) SOA - D) CNAME

Q39. Which DNS record **maps an IP address to a hostname**? - A) A - B) HINFO - C) PTR - D) SRV

Q40. Which DNS record includes the **CPU type and operating system** of the host? - A) RP - B) HINFO - C) TXT - D) SOA

Q41. SecurityTrails is best described as: - A) A DNS enumeration tool that creates a DNS map and enumerates current and historical DNS records and subdomains - B) A social engineering framework - C) An email tracking tool - D) A Google hacking database

Q42. In Fierce, the option `--traverse 10` instructs the tool to: - A) Perform 10 HTTP connections on discovered domains - B) Search for contiguous blocks of IPs within a range of 10 - C) List 10 subdomains at a time - D) Set the TTL to 10 hops

Part D — Network and Email Footprinting, Social Engineering, Tools and Countermeasures (Q43-Q60)

Q43. According to the IANA, which block is reserved for **private internets**? - A) 172.16.0.0 – 172.31.255.255 - B) 10.0.0.0 – 10.10.10.255 - C) 192.0.0.0 – 192.0.255.255 - D) 169.254.0.0 – 169.254.255.255

Q44. Traceroute works on the concept of the **ICMP protocol** and uses the: - A) TTL (Time to Live) field in the header of ICMP packets - B) Sequence number field of TCP packets - C) Fragment offset field of IP packets - D) Port number field of UDP packets

- Q45.** By default, **Windows** uses which traceroute utility? - A) `tracert` - B) `tcptraceroute` - C) `tracert` - D) `pathping`
- Q46.** When ICMP traceroute messages are **blocked** by network devices, the attacker uses: - A) UDP or TCP traceroute, also known as Layer 4 traceroute - B) Reverse traceroute - C) DNS traceroute - D) SNMP traceroute
- Q47. PingPlotter** is a traceroute tool that allows the attacker to: - A) Collect traceroute data and track latency and packet loss over time in readable graphs - B) Enumerate email addresses - C) Perform Whois lookups - D) Create fake social media profiles
- Q48. Email tracking** allows an attacker to collect information such as: - A) The recipient's IP address, geolocation, and operating system/browser details - B) The recipient's bank account passwords - C) The content of encrypted emails - D) The target's DNS zone files
- Q49.** Which of the following can be found in an **email header**? - A) The sender's IP address - B) The recipient's current password - C) The recipient's geolocation - D) The sender's browser history
- Q50. eMailTrackerPro** is used to: - A) Analyze email headers and extract the sender's geographical location and IP address - B) Create fake email accounts - C) Perform DNS enumeration - D) Scan social networks for usernames
- Q51. Social engineering** is best defined as: - A) The art of exploiting human behavior to extract confidential information - B) The use of automated tools to scan ports - C) The collection of information from public websites - D) The process of encrypting confidential data
- Q52. Shoulder surfing** is a technique whereby the attacker: - A) Intercepts any form of communication such as audio, video, or text - B) Secretly observes the target to gain passwords, PINs, and credit card information - C) Rummages through garbage bins for information - D) Pretends to be a legitimate or authorized person
- Q53. Dumpster diving** involves: - A) Collecting phone bills, contact information, and financial information from trash bins - B) Observing keystrokes over the victim's shoulder - C) Intercepting fax transmissions - D) Creating fake profiles on social networks
- Q54. Impersonation** is a social engineering technique where the attacker: - A) Pretends to be a legitimate or authorized person to mislead targets and trick them into revealing information - B) Eavesdrops on telephone conversations - C) Scans the target network for open ports - D) Analyzes the target's email headers
- Q55.** In theHarvester, the option `-b` specifies: - A) The number of results to retrieve - B) The data source (e.g., linkedin, baidu) - C) The target domain - D) The output file format
- Q56. FOCA** (Fingerprinting Organizations with Collected Archives) is mainly used to: - A) Find metadata and hidden information in scanned documents such as Office and PDF files - B) Track the most shared content on social networks - C) Perform Whois lookups - D) Enumerate employees on LinkedIn
- Q57. Maltego** is an automated tool used to: - A) Determine the relationships and real-world links between people, groups, organizations, websites, and Internet infrastructure - B) Analyze email headers - C) Perform shoulder surfing - D) Bypass firewalls
- Q58. subfinder** is a tool that helps attackers: - A) Discover valid subdomains for websites using passive online sources - B) Create Google dorks - C) Track email communications - D) Perform IP geolocation
- Q59.** In the **OSINT Framework**, the indicator **(T)** means: - A) The tool requires registration - B) The link points to a tool that must be installed and run locally - C) The entry is a Google dork - D) The URL must be edited manually
- Q60.** Which of the following is an **effective footprinting countermeasure**? - A) Setting apart internal and external DNS (split DNS) and restricting zone transfers to authorized servers - B) Publishing business plans on the company website - C) Allowing directory listings on web servers - D) Keeping the geo-tagging feature enabled on cameras

Answer Key

Part A

Q	Answer	Explanation
1	B	Footprinting = first/preparatory phase of gathering maximum info before an attack
2	B	Passive footprinting = no direct interaction; target unaware (OSINT, archived data)
3	B	DNS interrogation = active. Social networking sites, archive.org, Whois = passive
4	B	OSINT = Open-Source Intelligence
5	A	Organizational info: employees, phone numbers, branches, partners, history
6	C	Network info: domains, sub-domains, NetBlocks, topology, routers, IPs, Whois, DNS
7	C	System info: OS of web servers, server locations, emails, web technologies
8	B	Competitive espionage = competitors gather sensitive data to launch similar products
9	A	The footprint is a blueprint of the organization's security profile
10	B	No active traffic sent; only archived/stored information is collected
11	C	Social networking sites = passive (DNS interrogation, traceroute, email tracking = active)
12	B	Social engineering = collecting info via persuasion without technical intrusion
13	A	Passive phases: search engines → internet research services → social networking sites
14	B	Maltego, Recon-ng, FOCA, OSINT Framework are footprinting automation tools

Part B

Q	Answer	Explanation
15	B	<code>allinurl:</code> = all terms in the URL (vs <code>inurl:</code> = any/one term)
16	A	<code>site:</code> restricts results to a site or domain
17	C	<code>intext:</code> searches the term in the body of the page
18	B	<code>link:</code> cannot be combined with a normal keyword search per Google's docs
19	B	GHDB is a subset of Exploit-DB
20	A	SearchSploit = local copy of Exploit-DB for offline/air-gapped use
21	B	Shodan detects Internet-connected devices (IoT) and vulnerable networks
22	A	TinEye = reverse image search tool
23	B	FTP search engines: NAPALM, FreewareWeb, Mamont, Globalfilesearch
24	B	Meta engines query several third-party engines and mask the user's IP
25	B	Tor acts as a default VPN and bounces the IP through multiple servers
26	A	archive.org retrieves deleted/archived versions of websites
27	A	OS fingerprinting tools: Netcraft, Shodan, Censys

Part C

Q	Answer	Explanation
28	B	Social networking footprinting = gathering info available on the sites (not tricking people)

Q	Answer	Explanation
29	B	theHarvester enumerates LinkedIn employees + job titles
30	B	Sherlock searches a username across many social networking sites
31	A	BuzzSumo = most shared content for a topic/author/domain
32	B	Whois listens on port 43 (TCP)
33	C	RIPE NCC covers Europe
34	B	Thin Whois stores only the name of the registrar's Whois server
35	A	Whois returns NetRange, creation/expiry dates, name servers, registrar
36	A	IP geolocation: country, city, ISP, timezone, etc.
37	C	AAAA = host's IPv6 address (A = IPv4)
38	B	MX = mail server of the domain
39	C	PTR maps an IP address to a hostname (reverse DNS)
40	B	HINFO = CPU type and OS
41	A	SecurityTrails = DNS map, current + historical records, subdomains via brute-force
42	B	--traverse 10 = search contiguous IP blocks within a range of 10

Part D

Q	Answer	Explanation
43	A	Private blocks: 10/8, 172.16/12 (172.16.0.0-172.31.255.255), 192.168/16
44	A	Traceroute uses ICMP + the TTL field of the IP header
45	C	Windows uses <code>tracert</code> (ICMP); Linux <code>traceroute</code> (UDP)
46	A	TCP/UDP traceroute = Layer 4, used when ICMP is blocked
47	A	PingPlotter tracks latency and packet loss over time
48	A	Email tracking: recipient IP, geolocation, OS/browser, read time, device type
49	A	Email header contains the sender's IP address, dates, authentication system
50	A	eMailTrackerPro analyzes email headers (geo location, IP)
51	A	Social engineering = exploiting human behavior to extract confidential info
52	B	Shoulder surfing = secretly observing the target
53	A	Dumpster diving = rummaging trash bins for sensitive info
54	A	Impersonation = pretending to be a legitimate person to trick targets
55	B	-b = data source (linkedin, baidu, google, bing...); -l = results limit; -d = domain
56	A	FOCA finds metadata/hidden info in Office/PDF documents
57	A	Maltego determines relationships between people, organizations, websites, infrastructure
58	A	subfinder = passive subdomain discovery
59	B	(T) = tool to install and run locally; (D) = dork; (R) = registration; (M) = manual edit
60	A	Split DNS + restricted zone transfers is a footprinting countermeasure

Indicative scoring

- **50-60 correct:** excellent — ready for the exam
 - **40-49:** good — review the missed sections
 - **30-39:** average — restudy the course, then retry
 - **< 30:** re-read the complete Module 02 course document
-

Dump generated from the content of CEH v13 Module 02 (Footprinting and Reconnaissance). In case of OCR transcription errors, the official EC-Council PDF remains the reference.